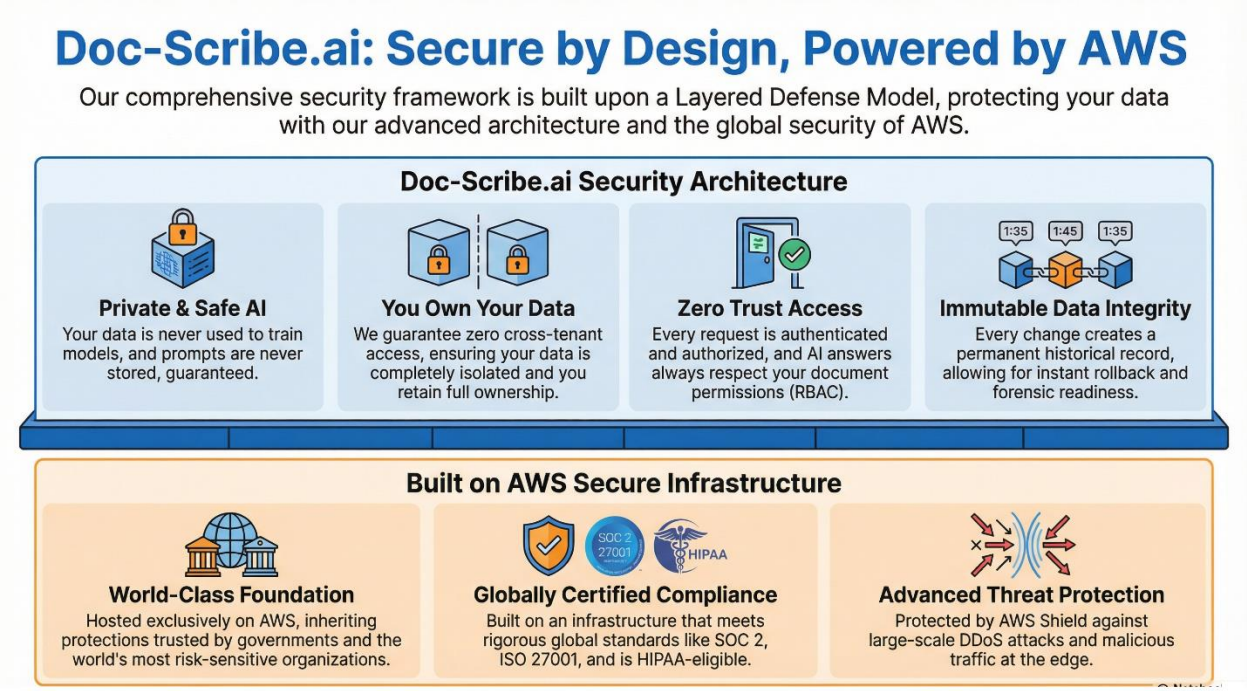
Doc-Scribe.ai 安全架构与合规性白皮书

1. 执行摘要：对数据信任的承诺

在 Doc-Scribe.ai，安全性和信任并非附加功能，而是我们数字管理系统（DMS）的基石。我们深知文档的完整性、保密性和可用性至关重要。我们全面的安全框架基于**分层防御模型构建，充分利用亚马逊云服务（AWS)**的全球安全合规性，并集成专有的安全架构，从而在数据生命周期的各个阶段提供全面保护。

2. 安全基础设施：AWS 基础架构

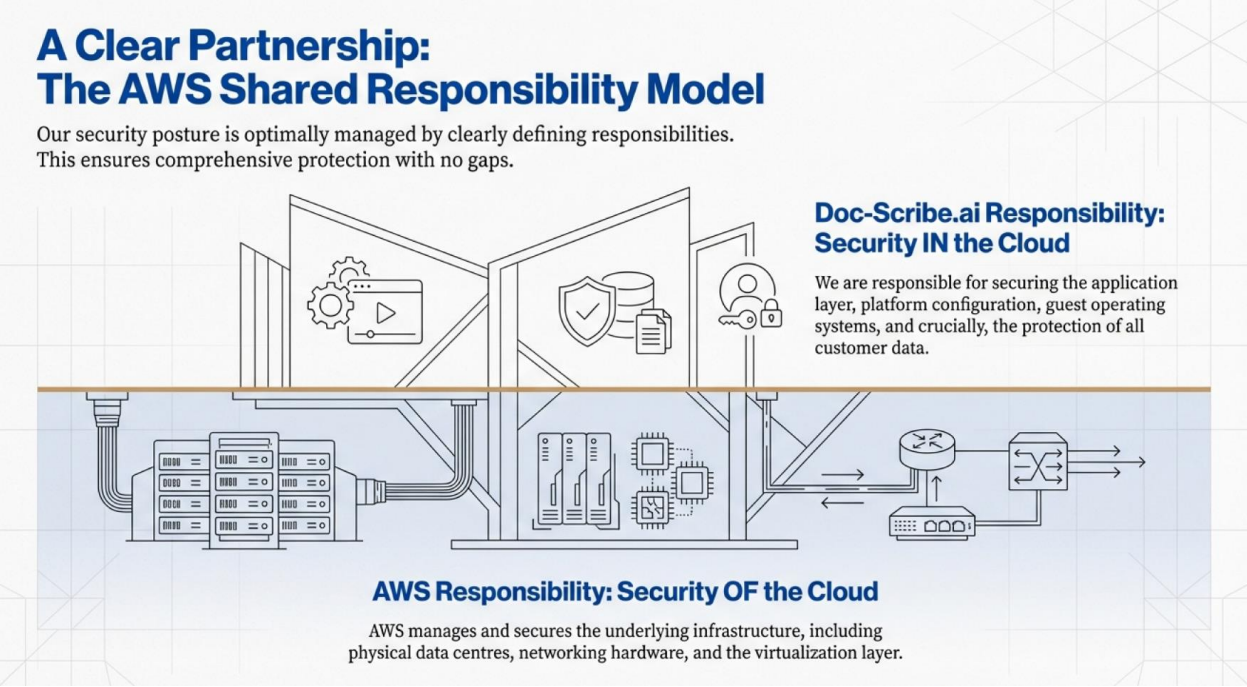
Doc-Scribe.ai 完全托管于亚马逊云服务（AWS)，AWS 是云基础设施领域的行业领导者。此次合作使我们能够继承一个经过全球验证的安全基础架构，该架构旨在满足全球风险敏感型组织严苛的要求。



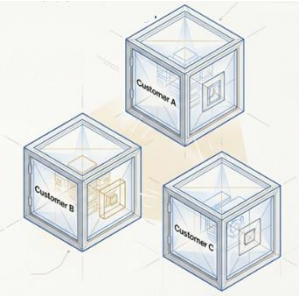
我们通过遵循 AWS 共享责任模型来优化安全态势管理：

- **云安全（AWS 责任）：** AWS 管理底层基础设施的安全，包括数据中心、网络硬件和虚拟化层。该基础设施已通过多项主要合规性标准的认证，包括SOC 1/2/3、ISO 27001、HIPAA 认证和 PCI DSS 1 级认证。

- **云端安全（Doc-Scribe.ai 的责任）：** Doc-Scribe.ai 负责应用层安全、客户操作系统、平台配置和客户数据保护。我们的***无服务器架构采用***AWS Firecracker **微型虚拟机隔离技术**进行保护，确保每个进程都在安全的硬件虚拟化沙箱中执行。



3. 数据治理与保密



3.1 严格的租户隔离和数据所有权

客户数据神圣不可侵犯。您对上传到 Doc-Scribe.ai 平台的所有文档及相关元数据拥有完全且唯一的所有权。

- **零跨租户可见性：**我们的平台采用 AWS 原生隔离控制。贵组织的数据在存储和计算层面上都与其他所有客户的数据在逻辑、物理和计算层面完全隔离，从而保证绝对**严格的租户隔离**。

3.2 高级身份验证和会话完整性

我们采用最先进的加密协议来安全地管理访问和会话。

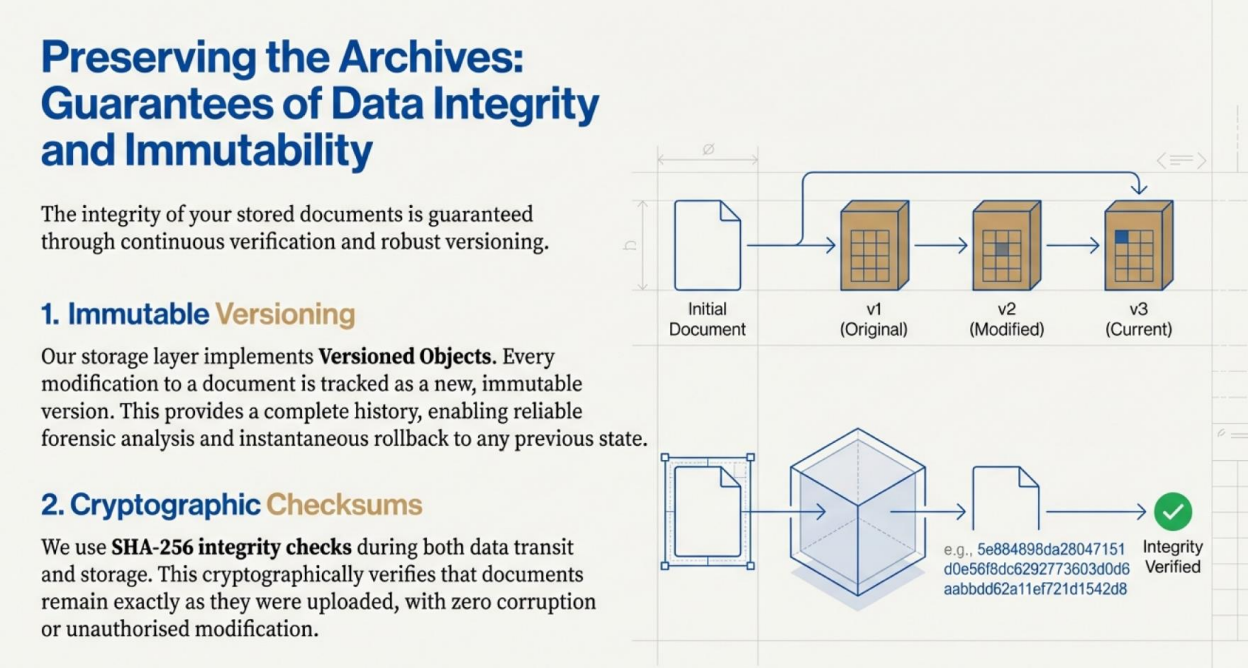
- **安全远程密码（SRP）协议：** SRP 用于主要身份验证，确保您的密码即使在加密状态下也不会在网络中传输。它依靠零知识证明来验证身份，从而有效防御中间人攻击和重放攻击。

- **基于 JWT 的会话安全：**用户成功登录后，系统会向其颁发**有效期短暂、经过加密签名的** JSON Web Tokens（JWT）。这些令牌会自动轮换，并在每次请求时进行验证，以维护会话的完整性并最大限度地降低风险。

- **多因素身份验证（MFA）：**全面支持企业级 MFA，在传统密码之外建立了至关重要的第二层防御。

3.3 数据完整性和不可篡改性

通过持续验证和强大的版本控制来保证存储数据的完整性。



4. 企业级人工智能安全和隐私

我们集成的 AI 功能旨在确保企业安全，并利用Amazon Bedrock解决关键的业务隐私问题。“无需训练”和“零持久性”保证

Doc-Scribe.ai 提供具有合同约束力的保证，确保您的数据绝不会用于训练模型。

- **数据不用于训练：** Amazon Bedrock 保证您的输入提示和 AI 生成的补全结果**不会**用于训练或改进任何底层基础模型。数据绝不会与第三方模型提供商共享。

- **零持久性保证：**所有提示和AI响应均为**临时性的**。底层AI基础设施不会记录或保留这些内容，用于模型改进或任何其他永久存储目的。

- **私有知识库：**您的文档将被索引到一个专用的、隔离的知识库中，该知识库专为您的组织而设。此索引采用与保护您的主文档库相同的**AWS 级安全控制措施进行保护**。

5. **网络架构和访问控制：零信任和DDoS防护**

我们实施严格的**零信任架构，**在未经证实之前，每个用户和每个请求都被视为不可信。

- **基于角色的访问控制 (RBAC)：**对 AI 和搜索结果的访问严格受您分配给用户的**文档级权限控制**，确保只有授权人员才能查看或与特定数据交互。

- **身份协议：**每个请求都使用企业标准身份协议（ OIDC/SAML ）进行身份验证和授权。

- **全球 DDoS 防护：**我们利用AWS Shield和先进的边缘安全服务，提供全面的防护，抵御恶意流量和分布式拒绝服务 (DDoS) 攻击。

6. **合规性和可审计性**

我们的安全控制措施经过验证且可审计，符合国际监管要求。

- **全球合规框架：** Doc-Scribe.ai 在经过审计的环境中运营，符合世界上最严格的合规标准，包括GDPR、SOC 2 II 型、ISO 27001 和 HIPAA 资格。

- **不可篡改的审计跟踪：**您环境中执行的每一个操作都会记录到不可篡改的AWS CloudTrail 和 CloudWatch 日志中，从而提供全面且防篡改的记录，这对于您的合规性和取证审查至关重要。

7. 资源和联系信息

如需了解我方基础设施合作伙伴提供的安全保障的官方技术验证，请参阅以下资源：

- **AWS 云安全基础：** https://aws.amazon.com/security/
- **Amazon Bedrock 数据隐私与安全：** https://aws.amazon.com/bedrock/security-compliance/
- **AWS 合规计划：** https://aws.amazon.com/compliance/programs/

如需了解更多详情、启动安全尽职调查或索取我们最新的合规认证，请联系我们的团队 doc-scribe@ambersoft.net